Threat Modeling

ask the attacker's question before launch

Watch the 4-min video

In one line: draw how data flows and where it crosses trust boundaries, ask the six STRIDE questions of every element, then rank threats by likelihood and impact and fix the high ones before launch, cheaper on a whiteboard than after a breach.

1 The question nobody asked

A file-upload feature is ready: code reviewed, tests green. Nobody asked how it could be abused. **Threat modeling** asks that on purpose, at design time. Adam Shostack's four questions frame it: *What are we working on? What can go wrong? What are we going to do about it? Did we do a good job?*

2 Data flows and trust boundaries

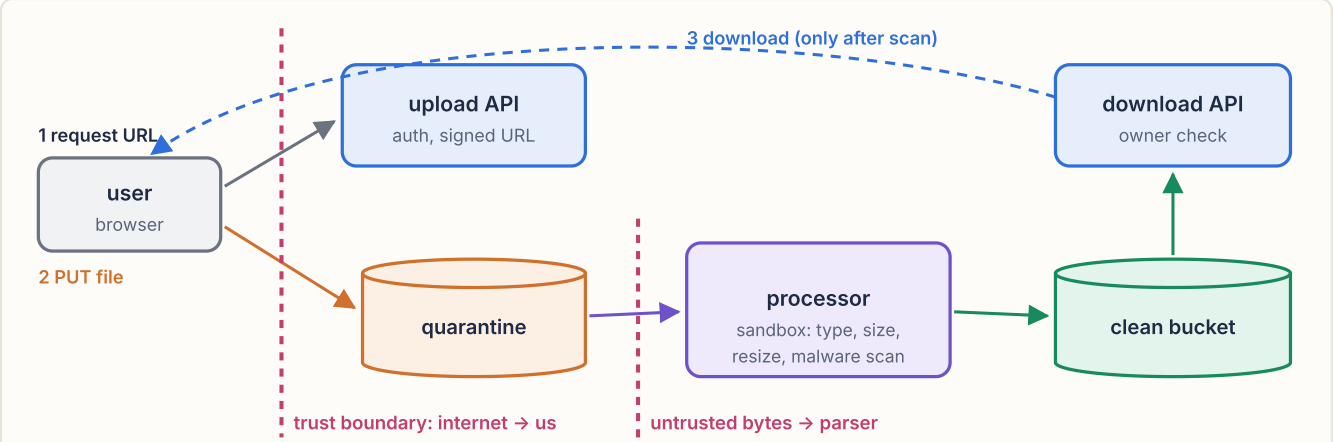


Figure 1. A data flow diagram of the upload feature. Dashed lines are trust boundaries, where untrusted input must be checked.

Draw **actors**, **processes**, **data stores** and **flows**. Then draw **trust boundaries**: where data moves between levels of trust (internet → API, your app → third party, user file → parser). Most attacks happen at those lines, so that's where validation and authentication belong. The **attack surface** is everything reachable: endpoints, parameters, file parsers, admin panels, queues, debug ports. Remove what you don't need.

3 STRIDE

Threat	Violates	Question	Upload example → mitigation
Spoofing	authentication	can someone pretend to be another user?	anonymous uploads → auth + short-lived signed URL
Tampering	integrity	can data be changed in transit or at rest?	file swapped after scan → immutable key, checksum
Repudiation	non-repudiation	can someone deny what they did?	"I never uploaded that" → audit log of uploader (lesson 55)
Information disclosure	confidentiality	can data leak?	public bucket, guessable names → private bucket, random keys
Denial of service	availability	can it be overwhelmed?	10 GB files, zip bombs → size limits, rate limits
Elevation of privilege	authorization	can someone gain rights?	parser exploit (e.g. ImageTragick) → sandboxed processing

Walk every element and flow in the diagram with these six questions. Other methods exist (attack trees, PASTA, LINDDUN for privacy), but STRIDE on a data flow diagram is the common interview answer.

4 Prioritize and record

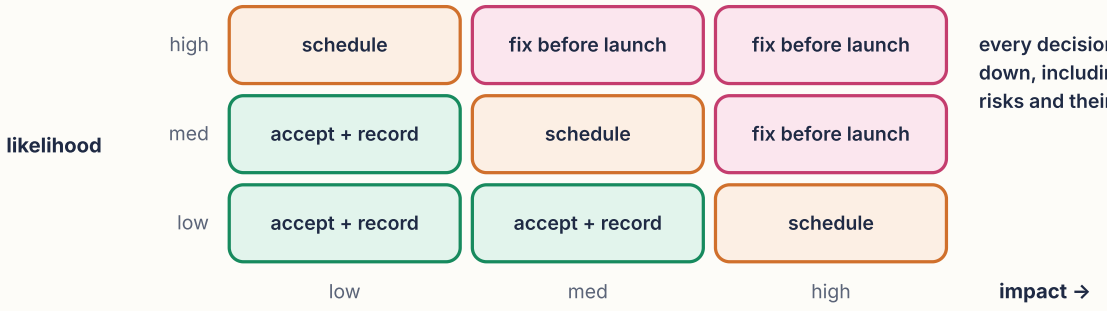


Figure 2. Rate each threat by likelihood and impact. A threat accepted on purpose is fine; a threat nobody noticed is not.

Keep it lightweight: an hour at a whiteboard with a developer, someone from security and someone who knows the product catches most big problems. Store the model with the design doc (OWASP Threat Dragon or the Microsoft Threat Modeling Tool help) and revisit it when the design changes: a new data store, integration or trust boundary.

WORKED EXAMPLE: THREAT MODEL OF A FILE UPLOAD SERVICE

S: require login; the API issues a signed upload URL valid for 5 minutes for one object key. **T/E**: the file lands in a quarantine bucket; a sandboxed worker (no network, no credentials, CPU and memory limits) checks magic bytes against an allowlist, enforces a size limit, re-encodes images, and runs a malware scan. **I**: private bucket, random keys, downloads only through an API that checks ownership, served with `Content-Disposition: attachment` from a separate domain. **D**: per-user upload rate and quota. **R**: audit every upload and download.

COMMON MISTAKES

- Threat modeling after launch, or only once, as a compliance document.
- Trusting the file extension or the client's `Content-Type`.
- Listing threats without owners, priorities or decisions.
- Modeling only the happy path and ignoring admin tools, queues and batch jobs.

5 Key terms

Threat model: structured list of what can go wrong and what you'll do

Data flow diagram: actors, processes, stores and flows

Trust boundary: where data crosses between trust levels

Attack surface: everything an attacker can reach

STRIDE: spoofing, tampering, repudiation, disclosure, DoS, elevation

Risk acceptance: a recorded, owned decision not to fix now

6 Interview questions

Q1. What does STRIDE stand for? BASIC

Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege; each violates authentication, integrity, non-repudiation, confidentiality, availability and authorization respectively.

Q2. How do you prioritize threats? BASIC

By likelihood and impact: fix the high ones before launch, schedule the medium ones, consciously accept the low ones, and record every decision.

Q3. Threat model a file upload feature. SCENARIO

Draw the data flow and the trust boundary where files enter, then apply STRIDE: authenticate uploads (signed URLs), validate type and size, process in a sandbox, store privately with random names, rate limit per user, and scan for malware before anyone can download.

Q4. Your team adds a third-party webhook integration. What changes in the threat model? SCENARIO

A new trust boundary: verify webhook signatures and timestamps (spoofing, replay), validate payloads, rate limit, and don't let it reach internal services (SSRF).

Q5. What is a trust boundary, and why focus there? TRICKY

A point where data or control passes between different trust levels; attacks enter there, so authentication and validation must happen there.

Q6. When should you redo a threat model? TRICKY

Whenever the design changes materially (new data store, integration, trust boundary or sensitive data), and after incidents that reveal a missed threat.

Next: SD-M-017 · Audit Logging